

Access Control Policy

Sanwo – Fintech Company Case Study

Document Classification: Internal Use Only

Policy Owner: Information Security Department

Version: 2.0

Effective Date: May 21, 202

Prepared by:

Zainab Adewumi Taofeek

Introduction

Sanwo is a fictional fintech company that provides digital payment solutions, wallet services, merchant payment processing, and online financial transaction services.

As a financial technology organization handling sensitive customer and financial information, Sanwo recognizes the importance of implementing strong access control measures to protect systems, applications, networks, and data from unauthorized access, misuse, disclosure, alteration, or destruction.

This Access Control Policy establishes the requirements and standards for managing access to Sanwo's information assets and technology resources.

Purpose

The purpose of this policy is to:

- Protect customer, financial, and organizational information from unauthorized access
- Ensure access to systems and data is granted based on legitimate business requirements
- Reduce cybersecurity and operational risks associated with inappropriate access
- Support regulatory compliance and security best practices
- Establish standardized access management procedures across the organization

Scope

This policy applies to:

- All employees of Sanwo
- Contractors, consultants, and temporary staff
- Third-party vendors and service providers
- Interns and external partners
- All systems, applications, databases, cloud services, endpoints, and network resources owned or managed by Sanwo

The policy covers both physical and logical access to organizational resources.

Access Control Principles

Sanwo shall implement access management controls based on the following principles:

1. Least Privilege

Users shall be granted the minimum level of access necessary to perform assigned job responsibilities.

2. Need-to-Know Access

Access to confidential or sensitive information shall only be provided to authorized individuals with a valid business requirement.

3. Role-Based Access Control (RBAC)

Access permissions shall be assigned according to predefined job roles and responsibilities.

4. Segregation of Duties

Critical business processes shall be separated among multiple individuals to reduce the risk of fraud, misuse, or unauthorized activities.

5. Multi-Factor Authentication (MFA)

MFA shall be enforced for privileged accounts, remote access, cloud platforms, and other critical systems.

Confidentiality and Acceptable Use

All users granted access to Sanwo systems and information assets are responsible for protecting organizational and customer information.

Requirements

- Employees and third parties must sign confidentiality or non-disclosure agreements where applicable
- Users shall handle sensitive financial and customer data responsibly

- Unauthorized sharing, copying, or disclosure of confidential information is prohibited
- Access to customer information must comply with organizational policies and regulatory obligations
- Users must comply with Sanwo’s acceptable use and security requirements

User Identification and Authentication

Unique identification and secure authentication mechanisms shall be implemented to ensure accountability and secure access.

Authentication Requirements

Requirement	Standard
Unique user IDs	Required for all users
Shared Accounts	Prohibited unless formally approved
MFA	Mandatory for critical systems
Authentication Logs	Must be retained and monitored
Session Timeout	Automatic timeout after inactivity
Failed login attempt	Account lockout after 5 failed attempts

Additional Controls

- Users must not share authentication credentials
- Default system credentials must be changed immediately
- Authentication systems shall use secure encryption methods
- Access to sensitive systems shall require enhanced authentication controls

User Account Management

User access shall be managed throughout the account lifecycle.

1. User Provisioning

All access requests must follow formal approval procedures.

Process	Requirement
New User Access	Requires management approval
Access Authorization	Approved by system owner
Role Assignment	Based on business responsibilities
Temporary Access	Time-bound and monitored
Third-party Access	Requires security approval

2. Access Modification

Access rights must be reviewed and updated whenever:

- Employees change job roles
- Responsibilities change
- Access requirements are modified

3. Employee Leavers

User accounts must be disabled or removed immediately upon:

- Resignation
- Termination
- Contract expiration
- Unauthorized activities

4. Dormant Accounts

Inactive accounts exceeding 90 days shall be disabled pending review.

Password Requirements

Strong password practices are required to protect Sanwo systems and information assets.

Requirements	Standard
Minimum Password Length	12 Characters
Complexity Requirement	Uppercase, lowercase, numbers and symbols
Password Reuse	Last 3 password prohibited
Password Expiration	Every 90 days
Password Storage	Securely hashed and encrypted
MFA Requirement	Mandatory for sensitive systems

Additional Requirements

- Passwords must not be written in unsecured locations
- Password sharing is prohibited
- Service account credentials must be protected securely
- Weak or commonly used passwords are prohibited

Privileged and Administrative Access

Privileged accounts present elevated security risks and shall be strictly controlled.

Requirements

- Administrative access must be formally approved
- Privileged accounts shall be uniquely assigned to individuals
- Shared administrator accounts are prohibited unless explicitly authorized
- Administrative activities must be logged and monitored
- MFA is mandatory for privileged accounts
- Privileged access reviews shall be conducted quarterly

Monitoring Requirements

The organization shall monitor:

- Administrative login attempts
- Configuration changes
- Sensitive data access
- High-risk privileged activities

Remote Access Controls

Remote access to organizational resources must be secured appropriately.

Remote Access Requirements

- VPN usage is mandatory for remote connections
- MFA is required for all remote access sessions
- Only company-approved devices may access internal systems
- Endpoint protection software must be enabled
- Access from public or unsecured networks should be minimized

Third-Party Remote Access

Third-party remote access shall:

- Be formally approved
- Be restricted to required systems only
- Be time-limited where possible
- Be monitored and logged continuously

Access Reviews and Monitoring

Sanwo shall conduct regular reviews and monitoring activities to ensure access rights remain appropriate.

Review Type	Frequency
User Access Review	Quarterly
Privileged Access Review	Quarterly
Third Party Access Review	Bi-annually
Dormant Account Review	Monthly

Monitoring Activities

The organization shall monitor:

- Failed login attempts
- Suspicious authentication activities
- Remote access sessions
- Privileged account usage
- Unauthorized access attempts

Security logs shall be retained and protected from unauthorized modification.

Policy Compliance

Failure to comply with this policy may result in:

- Access revocation
- Disciplinary action
- Contract termination
- Legal or regulatory consequences where applicable

Users must report suspected access-related incidents, account compromises, or policy violations immediately to the Information Security Team.

Exceptions to this policy must:

- Be formally documented
- Include valid business justification
- Receive management and security approval
- Be reviewed periodically

Roles and Responsibilities

Role	Responsibility
Information Security Team	Policy enforcement and monitoring
IT Department	User provisioning and technical implementation
Managers	Approval of user access requests
Employees	Compliance with security requirements
Internal Audit	Periodic compliance assessments

Review and Maintenance

This policy shall be reviewed annually or whenever significant changes occur to:

- Business operations
- Regulatory requirements
- Technology infrastructure
- Security risks
- Organizational processes

Policy updates must be approved by management prior to implementation.

References

This policy aligns with recognized standards and best practices, including:

- ISO/IEC 27001 Information Security Controls
- NIST Cybersecurity Framework (CSF)
- NIST SP 800-53 Access Control Guidelines
- Principle of Least Privilege
- Role-Based Access Control (RBAC)

Conclusion

Strong access control practices are essential to protecting Sanwo's systems, financial services, customer information, and business operations.

By implementing effective authentication controls, enforcing least privilege principles, managing privileged access securely, and continuously monitoring access activities, Sanwo can reduce cybersecurity risks, strengthen operational resilience, and maintain customer trust.